Privacy and security choices

Scope and roles

Local hackathon prototype with synthetic data. The Digital Personal Data Protection Act, 2023 and notified DPDP Rules, 2025 inform the design; commencement is phased. This is not a compliance certification. In a real deployment, the operator determining purpose/means would be the Data Fiduciary; contracted processing vendors would be Data Processors. Those contracts and owners are not established in this demo.

Notice, purpose and consent

A versioned notice explains business-document checks, the demo order and retention before upload. Affirmative consent and its timestamp are recorded. KYC images are processed locally; the advisor receives only the typed business description. Users are asked not to put personal identifiers in that description. No document data is sent to the model by the application.

Minimisation and retention

Public responses mask identifiers and omit private OCR text. Quotes retain calculated results, not the entered GSTIN. Tesseract processes a derived image through memory pipes; it does not persist uploaded images. The optional Windows adapter deletes temporary images after processing. Extracted evidence is deleted after documentary clearance, operator approval, withdrawal or 30-day expiry checked on startup/access. Audit events remain until withdrawal. Source specimens and research notebooks are separate synthetic assets. Crash recovery, scheduled cleanup and backup erasure remain pilot prerequisites.

Rights and grievance

The design recognises access, correction, erasure, grievance and nomination rights. The prototype implements journey viewing, explicit identifier correction and consent withdrawal/deletion. It does not implement a full rights request or nomination service. Before launch, appoint and publish a responsible contact and accessible grievance route, with escalation and response tracking. No working grievance inbox is claimed here; team/contact details remain to be supplied.

Access controls and incident response

Random journey tokens are hashed server-side. Approval, scheduling and activation require a separate operator secret; customer access alone is rejected. Requests are validated and SQL parameters are bound. Localhost binding and no-store responses reduce exposure. Browser tokens, unencrypted SQLite and unauthenticated quote/registry routes remain limitations. Before a real pilot, add authenticated roles, secure sessions, TLS, encryption, monitoring and secret rotation.

For a breach, the proposed runbook is to contain access, preserve relevant evidence, assess affected people, notify the responsible owner and make required notifications to affected Data Principals and the Board under applicable commenced requirements. This response process and notification delivery are not automated in the prototype.

Accuracy and accountability

Automated clearance means synthetic documentary consistency checks passed, not verified identity or signing authority. Unreadable, inconsistent, stale or inactive evidence stays in review. OCR and AI accuracy results are published separately.

Sources: DPDP Act, 2023 (MeitY); DPDP Rules, 2025 (MeitY Gazette, phased commencement). Source links are provided in docs/PRIVACY_NOTE.md.